Biomedical Research, Clinical Data Sharing & Patient Privacy Policy

Enterprise Compliance Directive • Ref: POL-BIO-007

ORGANIZATIONAL POLICY MANUAL	**Policy Code:** POL-BIO-007
Document: Biomedical Research, Clinical Data Sharing & Patient Privacy Policy	**Version:** 2.2 | **Effective:** 2025-02-15
Category: Healthcare & Life Sciences Compliance	**Business Area:** Clinical Research, R&D; & Health Informatics
Compliance Owner: Chief Medical Officer & Institutional Review Board (IRB)	**Classification:** Confidential - Internal Corporate Use

1. Policy Purpose & Executive Scope

Governs the ethical collection, de-identification, secure processing, and publication of human health data, clinical trial records, and biomedical abstracts adhering to HIPAA and FDA regulations.

2. Binding Regulatory Clauses & Compliance Requirements

Section 1.2: Protected Health Information (PHI) De-Identification Standards [POL-BIO-007-C01]

Requirement: MANDATORY | Risk Impact: CRITICAL | Regulatory Base: HIPAA Privacy Rule 45 CFR § 164.514(b); HITECH Act

Patient clinical abstracts, diagnostic records, or genomic data used for secondary research, machine learning training, or academic publication must undergo complete de-identification in accordance with the HIPAA Privacy Rule Safe Harbor standard by removing all 18 specified direct and indirect identifiers (names, dates, geographic data below state level, medical record numbers, biometric IDs), or through statistical certification by a qualified expert.

Section 2.1: Institutional Review Board (IRB) Protocol & Informed Consent [POL-BIO-007-C02]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: Common Rule 45 CFR 46; FDA 21 CFR Parts 50 & 56

Any research study, biobanking initiative, or secondary analysis involving human subjects or identifiable private health information must receive formal Institutional Review Board (IRB) approval prior to data ingestion. Participants must execute an Informed Consent Form that explicitly enumerates prospective secondary use, algorithmic analysis, and potential third-party research collaboration.

Section 3.3: Business Associate Agreements (BAA) for Health Data Clouds [POL-BIO-007-C03]

Requirement: MANDATORY | Risk Impact: CRITICAL | Regulatory Base: HIPAA Security Rule 45 CFR Part 160 & Part 164 Subparts A & C

Cloud service providers, high-performance computing clusters, or AI infrastructure vendors storing or processing Protected Health Information (PHI) or identifiable clinical datasets must enter into a formal Business Associate Agreement (BAA) with the organization prior to any data transmission. Storing PHI on non-BAA covered commercial cloud tiers is

strictly prohibited.

Section 4.2: Electronic Records Audit Trail & FDA 21 CFR Part 11 Compliance [POL-BIO-007-C04]

Requirement: MANDATORY | Risk Impact: HIGH | Regulatory Base: FDA 21 CFR Part 11; Good Clinical Practice (GCP) ICH E6(R2)

Electronic systems used to manage clinical trial data, electronic case report forms (eCRF), or bio-sample tracking must maintain computer-generated, time-stamped audit trails that independently record the date, time, and operator of any entry, modification, or deletion. System access requires unique electronic signatures meeting FDA 21 CFR Part 11 criteria.